

# 3가지

## 취약점 스캐너



취약점 관리에는 여러 구성 요소가 있지만, 취약점 스캐너에서 수집하는 원시 데이터가 가장 중요합니다. 스캐너가 올바르게 구성되지 않았거나 잘못된 위치에 설치된 경우, 취약점 관리 프로세스의 나머지 단계에 필요한 데이터를 얻을 수 없습니다.

이 책은 네트워크 기반 스캐너를 사용하는 것을 전제로 합니다. 네트워크 기반 스캐너는 네트워크를 통해 패킷을 전송하고 특정 응답을 수신함으로써 시스템에 대한 정보를 학습합니다. 이 장에서는 네트워크 기반 취약점 스캐너의 작동 방식과 환경에서 이를 최대한 활용하는 방법에 대해 설명합니다.

### 취약점 스캐너의 역할

스캐너는 사용자가 스캔 대상으로 지정한 모든 장치의 운영 체제 및 실행 중인 서비스에 대한 모든 정보를 수집합니다. 수집된 정보를 바탕으로 스캐너는 해당 장치가 알려진 취약점에 취약한지 여부를 판단합니다. 취약점을 찾아냅니다. 지정된 네트워크 범위 내의 모든 장치에서 취약점 목록을 수집하는 작업이 완료되면 스캐너는 보고서를 생성합니다. 이 보고서에는 호스트 목록, 각 호스트에 대해 알려진 정보, 그리고 각 호스트에 존재하는 취약점이 포함됩니다. 이 보고서는 취약점 분석의 주요 구성 요소로 사용됩니다.

### 취약점 스캐너는 어떻게 작동할까요?

보안 관리자는 특정 네트워크 범위 또는 개별 시스템 (대상) 을 스캔하도록 스캐너를 구성합니다. 스캐너는 지정된 대상의 모든 IP 주소로 핑 패킷을 전송하여 호스트에 연결하고 어떤 장치가 활성화되어 응답하는지 확인합니다. 스캐너가 활성화 장치에 해당하는 IP 주소를 파악하면 추가 핑, 열린 포트에 대한 연결 요청 또는 특정 상태 메시지나 오류 응답을 유도하도록 조작된 패킷을 전송합니다. 관리자는 스캐너의 탐지 강도를 조절할 수 있습니다. 탐지 강도가 높을수록 스캐너는 각 장치에 수천 개의 패킷을 전송하여 어떤 포트가 열려 있는지, 장치 유형은 무엇인지 파악합니다.

스캐너는 장치가 무엇인지, 그리고 어떤 서비스가 실행 중인지 파악한 후 추가 정보를 확인하기 위해 프로브를 전송합니다. 예를 들어, 장치가 80번 포트(일반적인 웹 서버 포트)에서 수신 대기 중인 것을 감지하면 웹 서버에 연결하여 실행 중인 서버 소프트웨어(및 사용 중인 버전)를 확인합니다. 스캐너는 버전 정보를 자체 내부 취약점 데이터베이스와 대조합니다. 예를 들어, 장치가 특정 소프트웨어의 버전 3.1을 실행 중이고 해당 소프트웨어의 취약점이 버전 3.2에서 수정되었다면, 스캐너는 해당 장치가 해당 취약점에 취약하다고 보고합니다. 또한 일부 스캐너는 특정 취약점에 대한 특별 테스트를 제공합니다. 이러한 테스트는 해당 취약점 악용을 방지하는 다른 완화 조치가 이미 구현된 경우에 유용합니다.

스캔은 정확한 과학이 아닙니다. 지문 인식을 통해 장치에서 실행 중인 운영 체제를 파악하는 경우가 많지만, 예외적인 경우에는 오류가 발생할 수 있습니다. 예를 들어, 맞춤형 네트워크 스택으로 인해 장치가 다른 운영 체제를 실행하는 것처럼 보이거나, 적절한 지문 정보가 없는 드문 운영 체제가 잘못 식별될 수 있습니다.

취약점 발견에도 이와 유사한 수준의 불확실성이 존재합니다. 예를 들어, HTTP 서버가 Apache 2.2.0을 실행 중이라고 보고했는데, 스캐너가 해당 서버가 Apache 2.2.1 버전에서 수정된 특정 문제에 취약하다고 판단하는 경우가 있습니다. 하지만 해당 시스템 공급업체는 자체 개발한 Apache 2.2.0 버전에 이러한 수정 사항을 백포팅했기 때문에 실제로는 시스템에 취약점이 없습니다. 스캐너는 이러한 사실을 알 수 없으므로 시스템이 취약하다는 오탐을 보고하는 것입니다. 이러한 오류를 최소화할 수는 있지만, 오탐은 네트워크 취약점 스캔의 불가피한 부분입니다.

## 취약점 스캐너 배포 방법

시스템에 스캐너를 배포하는 방법에는 여러 가지 선택 사항이 있습니다. 여기에는 스캐너가 스캔해야 하는 네트워크에 대한 액세스 권한을 부여하는 방법, 실행되는 운영 체제 및 하드웨어, 그리고 환경에서 효과적으로 작동하도록 구성하는 방법 등이 포함됩니다.

## 스캐너에 접근 권한이 있는지 확인

네트워크 내에서 스캐너의 배치 위치는 매우 중요합니다. 로컬 네트워크 이외의 네트워크 세그먼트를 스캔하려는 경우, 스캐너는 라우터와 방화벽을 거쳐 패킷을 전송하게 됩니다. 이러한 장치에는 특정 유형의 트래픽을 차단하는 ACL(접근 제어 목록) 또는 방화벽 규칙이 있을 수 있으며, 이로 인해 스캐너의 프로브 패킷이 차단될 가능성이 높습니다. 따라서 스캐너를 배포하는 데에는 일반적으로 두 가지 방법이 있습니다.

먼저, 스캐너에서 스캔하려는 모든 네트워크 범위까지 중간 네트워크 장치를 통해 완전한 액세스를 허용할 수 있습니다. 이를 위해서는 스캐너의 트래픽을 IPS 정책에서 제외해야 할 수도 있습니다. 완전한 액세스를 허용하면 스캐너와 대상 사이에서 패킷이 차단되지 않아 잘못된 결과를 방지할 수 있습니다.

둘째, 여러 개의 스캐너를 설정할 수 있습니다. 각 스캐너는 스캔할 네트워크 세그먼트와 가까운 네트워크 토폴로지에 위치해야 합니다. 예를 들어, 방화벽이 설치된 *비무장지대(DMZ)*를 스캔하려면 DMZ 내부에 스캐너를 배치하여 스캔 대상 시스템에 직접 접근할 수 있도록 합니다. 두 가지 접근 방식 모두 장단점이 있습니다.

### 검색 제한 또는 무제한?

한 가지 견해는 모든 스캔을 "일반적인" 네트워크 환경에서 수행해야 한다는 것입니다. 즉, 스캐너는 해당 네트워크 세그먼트에서 권한이 없는 사용자가 방화벽 규칙이나 ACL에 의해 접근이 차단된 항목에는 접근할 수 없어야 한다는 것입니다. 공격자도 무제한 접근 권한을 갖지 못하는데, 스캐너도 그래야 한다는 논리입니다. 하지만 스캔을 실행할 때 공격자의 관점을 흉내 내려 해서는 안 됩니다. 기업 전체의 취약점을 완벽하게 파악하는 것이 중요합니다. 공격자가 다른 서브넷에 있다면 어떨까요? 공격자가 이미 "제한된" 네트워크의 시스템을 침해했다면 어떨까요? 스캐너는 제 역할을 다하기 위해 스캔 대상 시스템 전체를 볼 수 있어야 합니다.

### 스캐너에 대한 모든 액세스 권한 열기

스캐너 트래픽과 응답을 모두 수락하고 통과시키도록 네트워크를 구성하면 네트워크 내 어디에든 스캐너를 설치할 수 있습니다. 또한 여러 네트워크 세그먼트에 단일 스캐너를 사용하면 스캔 환경 설정 비용을 절감할 수 있습니다. 하지만 스캐너에 모든 접근 권한을 부여하는 것은 위험할 수도 있습니다. 공격자는 라우터 및 방화벽 인프라의 취약점을 악용할 수 있습니다. 공격자가 스캐너 시스템을 침해하면 해당 시스템에 접근하여 네트워크의 다른 시스템을 더욱 쉽게 공격할 수 있습니다.

### 여러 스캐너 설정하기

여러 개의 스캐너를 설정하는 것이 최선의 접근 방식처럼 보일 수 있습니다. 방화벽 포트를 열거나 ACL을 추가할 필요가 없기 때문입니다. 하지만 이 방법에도 단점이 있습니다.

첫째, 각 스캐너마다 물리적 또는 가상 하드웨어가 필요하기 때문에 초기 설정 비용이 더 많이 듭니다. 또한 상용 스캐너를 사용하는 경우 라이선스 비용이 하드웨어 비용보다 더 많이 들 수 있습니다.

둘째, 조정 문제가 발생할 수 있습니다. 각 스캐너에 직접 연결하여 스캔을 설정하고 결과를 개별적으로 검색하거나, 중앙 위치에서 스캐너를 관리할 수 있는 계층적 환경이 필요할 수 있습니다. 예를 들어, Tenable은 여러 Nessus 스캐너를 관리하는 Security Center를 판매하고 있으며, Qualys는 클라우드 기반 QualysGuard를 사용합니다. 이러한 조정 작업은 스캐너 배포에 시간과 비용을 추가합니다.

또한 분석가(또는 중앙 제어 시스템)가 다양한 네트워크 위치에서 이러한 스캐너에 액세스할 수 있도록 방화벽 포트를 열고 라우터 구성을 변경해야 할 가능성이 높습니다.

### **운영체제와 하드웨어 선택하기**

Qualys와 같은 일부 스캐너는 자체 어플라이언스를 사용하기 때문에 기본 시스템을 제어할 수 없습니다. 하지만 Nessus 및 OpenVAS를 포함한 다른 스캐너들은 사용자가 원하는 플랫폼에서 실행되는 애플리케이션입니다. 선택한 스캐너가 지원하는 운영 체제라면 어떤 운영 체제를 사용하든 상관없습니다. 익숙한 플랫폼을 사용하거나 조직의 정책에 맞는 플랫폼을 사용하면 됩니다.

하드웨어 사양을 고려할 때, 성능이 좋을수록 좋습니다. 스캐너는 여러 대상에 대해 동시에 많은 테스트를 실행하기 때문에 엄청난 양의 RAM을 사용하므로, RAM을 먼저 보강하는 것이 좋습니다. 일반적으로 소규모 배포 환경에서는 CPU 두 개와 8GB RAM이면 충분합니다. RAM 용량이 부족해도 작동은 하지만, 스캐너 실행 중에 시스템 응답 속도가 느려질 수 있습니다. 빠른 인터넷 연결(낮은 지연 시간과 높은 속도) 또한 필수적입니다. 그렇지 않으면 네트워크 테스트에 시간이 오래 걸리고, 완료 전에 시간 초과가 발생하여 오탐 또는 오분류가 발생할 수 있습니다.

### **스캐너 설정하기**

스캐너를 설치하고 온라인 상태로 만든 후에는 사용 환경에 맞게 스캐너를 조정해야 합니다. 스캐너에는 정책 또는 템플릿이라고 하는 다양한 구성 옵션이 있습니다. 이러한 옵션을 통해 스캐너가 패킷을 전송하는 속도, 실행할 테스트 유형 등 다양한 설정을 구성할 수 있습니다. 이러한 옵션을 통해 스캐너는 네트워크에 과부하를

주거나 스캔 대상 장치에 문제를 일으키지 않고도 유용한 결과를 반환할 수 있습니다. 테스트 환경이 있다면 지금 활용해 보세요. 스캔 정책을 구성한 다음 테스트 네트워크를 스캔합니다. 문제가 발생하면(예: 스캐너 작업으로 인한 네트워크 혼잡, 속도 저하 또는 장치 오작동) 문제가 해결될 때까지 정책을 조정합니다. 스캐너가 제대로 맞춤 설정되었다고 확신하면 실제 환경을 스캔할 수 있습니다. 테스트 네트워크에서 먼저 연습할 수 있는지 여부와 관계없이 전체 시스템을 스캔하기 전에 실제 네트워크의 일부 영역에서 몇 차례 스캔을 실행하는 것이 좋습니다. 전체 프로덕션 데이터베이스 환경을 재부팅해야 하는 것보다 지리적으로 가까운 몇몇 시스템에서 문제가 발생하는 것이 훨씬 낫습니다!

스캔 정책을 테스트하고 네트워크의 더 큰 부분 또는 전체 시스템을 스캔할 준비가 되면 스캔 대상과 일정을 설정하는 가장 좋은 방법을 고려해야 합니다. 스캔을 관리하기 쉬운 작은 단위로 나누는 데에는 몇 가지 이유가 있습니다. 한 번에 대규모 스캔을 실행하면 완료하는 데 매우 오랜 시간이 걸릴 수 있으며, 그 시간은 소규모 스캔에서 얻은 데이터를 분석하는 데 사용할 수 있습니다. 여러 스캐너를 사용하는 경우 각 스캐너가 올바른 네트워크를 대상으로 하도록 스캔을 설정해야 합니다. 또한 스캔을 실행하기에 가장 적합한 시간은 네트워크 세그먼트마다 다를 수 있습니다. 워크스테이션 VLAN에서 업무 시간 외에 스캔을 실행하는 것이 관찮을 수 있지만, 일부 데이터 센터 환경에서는 해당 시간이 처리량이 가장 많은 시간대일 수 있습니다. 민감하거나 운영에 중요한 네트워크는 문제가 발생하여 시스템이 응답하지 않는 상황에 대비하기 위해 지정된 변경 시간까지 접근을 차단해야 할 수도 있습니다.

스캔 계획을 세울 때는 다른 이해 관계자들에게 스캔 계획과 정책을 알리고, 적절한 스캔 대상과 기간을 결정하는 데 참여시켜야 합니다. 계획 초기 단계부터 다른 사람들을 참여시키면 도메인 컨트롤러가 다운되는 스캔 실행과 같은 예상치 못한 상황에 직면하지 않도록 할 수 있습니다. Windows 관리자들이 자신의 시스템을 향후 스캔에서 제외해 달라고 요구하는 것을 막아야 합니다. 네트워크를 완벽하게 파악하려면 스캔을 시작하기 전에 스캔 계획에 대한 동의 또는 최소한 마지못한 수용을 얻어야 합니다. **6장**에서는 비즈니스 환경에서 스캔 및 복구 작업을 수행하는 방법에 대해 자세히 살펴보겠습니다.

일부 조직에서는 정기적인 자동 취약점 검사를 허용하지 않습니다. 이런 경우에는 분석가가 현장에 있는 상태에서 수동으로 검사를 실행하고, 검사 진행 상황을 모니터링해야 합니다. 검사 대상 시스템에서 문제가 발견되면, 분석가는 시스템 다운타임이 발생하거나 장기화되기 전에 검사를 중단할 수 있습니다.

가동 시간 요구 사항이 매우 엄격하고 유지 보수 시간이 극히 드문 조직은 실제 시스템 대신 연구실 시스템이나 이중화 시스템을 스캔 대상으로 사용할 수 있습니다. 추가 서버 세트 또는 전체 네트워크를 네트워크 구성, 운영 체제, 애플리케이션 및



패치 수준을 포함하여 복제합니다. 테스트 시스템에서 얻은 스캔 데이터는 원칙적으로 실제 시스템에서 얻은 데이터와 동일합니다.

하지만 시스템의 패치 수준을 완벽하게 동기화하는 것은 매우 어려울 수 있습니다. 구성상의 차이가 스캔 결과에 영향을 미칠 수 있는데, 예를 들어 연구실 시스템의 하스트 기바 바하버이 실제 시스템과 다른 포트 지하의 연어 노드 격으로 드 스 이



결과를 보장할 방법이 없습니다.

## 결과 얻기

스캐너는 다양한 방식으로 결과를 보고할 수 있습니다. 일반 텍스트 파일, XML이나 CSV와 같은 구조화된 형식, 또는 HTML, RTF, Word 파일, PDF와 같이 읽기 쉬운 형식 등이 있습니다. 보고서를 직접 읽기에는 마지막 형식이 더 적합하지만, 이 가이드에서는 XML 및 CSV와 같은 기계 판독 가능한 출력 형식에 중점을 둘 것입니다. 스캐너를 실행하고 결과를 수집하는 것은 단지 첫 단계일 뿐이기 때문입니다. 유용한 취약점 정보를 얻으려면 이 데이터를 분석해야 합니다. 대부분의 스캐너는 XML 형식으로 출력을 생성하며, 이 가이드에서도 주로 XML 형식을 사용할 것입니다. 하지만 구조화되고 컴퓨터가 파싱할 수 있는 형식이라면 무엇이든 사용할 수 있습니다.

## 요약

취약점 스캐너는 방대한 양의 정보를 생성할 수 있으므로, 취약점 분석가로서 어떤 정보가 유용한지 파악하는 것이 중요합니다. 취약점 스캐너를 적절하게 배포하고 구성하면 관련 없는 정보를 제외하고 중요한 데이터만 (또는 최소한 주로) 수집할 수 있습니다. 어떤 환경에서는 네트워크에 대한 다양한 관점을 얻거나 접근이 제한된 네트워크 영역에 대한 가시성을 확보하기 위해 여러 스캐너를 배포하는 것이 효과적일 수 있습니다. 또한, 스캔을 더 작은 대상으로 나누어 결과를 더 빠르게 얻거나 스캔으로 인한 네트워크 전체 장애 발생 가능성을 줄일 수도 있습니다.

또한, 여러분은 자신이 속한 더 넓은 운영 환경을 고려해야 합니다. 스캔은 시스템에 부담을 줄 수 있으며 극단적인 경우에는 시스템 다운타임을 초래할 수 있으므로 정기적인 취약점 스캔을 신중하게 도입해야 합니다. 적절한 대상과 일정을 결정하는 과정에 다른 팀을 참여시켜 스캔 오류 발생 시 모든 책임을 혼자 떠안지 않도록 하십시오.

다음 장에서는 스캐너가 생성하는 데이터를 수집하고 분석하는 방법을 배우게 됩니다. 또한 이 책의 실습 부분에서 직접 구축하게 될 자동화된 데이터 수집 및 분석 방

법도 소개합니다.